

GLOCAL(글로컬)캠퍼스 정보보안 내규

제정 2019. 12. 4.

제 1 장 총 칙

제1조(목적) 이 내규는 교육부 정보보안 기본지침(이하 “기본지침”이라 한다)에 따라 건국대학교 GLOCAL(글로컬)캠퍼스(이하“본교”라 한다)의 정보보안을 위해 필요한 사항을 규정함을 목적으로 한다.

제2조(정의) 이 내규에서 사용하고 있는 용어의 정의는 다음 각 호와 같다.

1. “정보통신망”이라 함은 전기통신기본법 제2조제2호의 규정에 따라 전기통신설비를 활용하거나 전기통신설비와 컴퓨터 및 컴퓨터의 이용기술을 활용하여 정보를 수집·가공·저장·검색·송수신하는 정보통신체제를 말하며 정보시스템 일체를 포함
2. “정보시스템”이라 함은 서버·PC등 단말기, 보조기억매체, 네트워크 장치, 응용 프로그램 등 정보의 수집·가공·저장·검색·송수신에 필요한 하드웨어 및 소프트웨어를 말함
3. “정보보안”이라 함은 정보시스템 및 정보통신망을 통해 수집·가공·저장·검색·송수신되는 정보의 유출·위변조·훼손 등을 방지하기 위하여 관리적·물리적·기술적 수단을 강구하는 일체의 행위로서 사이버안전을 포함
4. “시스템관리자”라 함은 정보통신서비스에 이용되는 정보통신망과 정보시스템을 관리·운영하는 자를 말함
5. “이용자”라 함은 정보통신서비스를 이용하는 자를 말함
6. “정보보호시스템”이라 함은 정보시스템 및 정보통신망을 침해사고로부터 보호하기 위해 설치한 각종 하드웨어 및 소프트웨어를 말함
7. “정보자산”이라 함은 정보통신망, 정보시스템, 정보보호시스템 등을 통칭
8. “전산센터”라 함은 서버·PC 등과 스위치·라우터 등 네트워크 장치 등이 설치 운용되는 장소를 말함
9. “침해사고”라 함은 외부 또는 내부의 악의적인 사용자에게 의한 비인가된 시스템 사용, 사용자 계정의 도용, 악성코드(웜/바이러스/트로얀) 유입 및 실행, 정보시스템 방해 등 시스템의 서비스를 왜곡 또는 지연시키거나 시스템을 파괴, 데이터를 변조, 삭제하는 등의 행위를 말함

제3조(정보보안 책임) 본교의 교원, 직원, 행정조교, 수업조교, 보조인력, 용역인력과 학생(이하 “구성원”이라 한다)에게는 학교 내에서 자신이 속하는 부서의 정보자산에 대하여 이 내규와 이 내규에 따른 지침을 준수할 의무가 있다.

제 2 장 정보보안 조직

제4조(정보보안 조직) ①본교 정보보안담당부서는 기획처 정보운영팀으로 한다.

②정보보안 조직은 정보보안담당관, 정보보안실무책임자, 정보보안담당자로 구성한다.

③정보보안담당관은 기획처장이 겸한다.

④정보보안실무책임자는 정보운영팀장이 겸한다.

⑤정보보안실무책임자는 정보보안담당자를 임명한다.

제5조(정보보안담당관의 역할) 정보보안담당관은 정보보안 관련업무를 총괄하며, 다음과 같은 업무를 수행한다.

1. 정보보안 정책·계획의 수립·시행
2. 정보보안 관련 규정·지침 등 제·개정
3. 정보보안 전담조직 관리, 전문인력 및 관련예산 확보
4. 정보화사업 보안성 검토 및 보안적합성 검증 총괄
5. 정보통신실, 정보통신망 현황자료 등에 관한 보안관리 총괄
6. 주요 정보통신 기반시설 보호
7. 사이버공격 대응훈련 및 정보보안 수준진단 총괄
8. 보안관계, 사고대응 및 정보협력 업무 총괄
9. 정보보안교육 총괄 및 '사이버보안진단의 날' 계획 수립·시행
10. 정보보안점검
11. 부서 분임정보보안담당관 업무 감독
12. 그 밖에 정보보안과 관련한 사항

제6조(분임정보보안담당관 운영) ①정보보안담당관이 직무를 효율적으로 수행할 수 있도록 각 부서에 분임정보보안담당관을 임명해야 하며, 별도로 임명하지 아니할 경우 부서의 장을 분임정보보안담당관으로 임명한 것으로 본다.

②정보보안담당관은 제5조 각 호에 해당하는 업무의 일부를 부서 분임정보보안담당관에게 위임할 수 있다.

제7조(정보보안실무책임자의 역할) 정보보안실무책임자는 정보보안담당관으로부터 위임받은 업무와 정보보안 수준을 유지하기 위하여 다음과 같은 업무를 수행한다.

1. 정보보안 정책·규정 및 대책 수립
2. 정보자산 신·증설에 따른 보안성 검토
3. 정보보안 세부추진계획 검토 및 추진결과 심사·평가
4. 기타 정보보안 관련 업무

제8조(정보보안담당자의 역할) 정보보안담당자는 정보보안실무책임자를 보좌하고 정보보안 수준을 유지하기 위하여 다음과 같은 업무를 수행한다.

1. 정보자산 최신 현황 관리 및 유지
2. 정보자산 보안성 검토
3. 정보보호시스템의 운영 및 유지관리
4. 정보침해사고 대응 및 행정처리, 정보보안 감사업무 처리
5. 정보보안 홍보 및 구성원 교육
6. 정보보안 세부추진계획 수립·시행 및 추진결과 분석
7. 기타 위 각 호에 부수되는 제반 사항

제3장 정보보안 활동

제9조(정보보안 조직의 구성) 본교의 정보보안 조직체계는 정보보안담당관이 조직을 총괄하고, 정보보호분과위원회, 정보보안실무책임자, 정보보안담당자로 구성 운영하며, 부서(팀)별 보안활동 및 관리를 위해 해당 부서(팀)의 책임자를 부서별정보보안담당자로 지정한다.

1. 정보보안 조직의 주요 역할은 다음과 같다.

- 가. 정보보안 활동 계획의 수립, 시행
- 나. 정보보안 규정, 지침의 검토 수립
- 다. 침해사고에 대한 예방, 분석, 대책 수립
- 라. 정보보호 교육 계획 수립, 시행
- 마. 상기 업무와 관련한 기타 제반 업무

2. 정보보안 조직 구성원은 정보보안 활동을 원활하게 수행할 수 있도록 다음 사항을 고려하여 임명하여야 한다.

- 가. 정보보안 전문지식 보유 여부 (예: 정보보호 관련 학위 또는 자격증 보유 여부)
- 나. 정보보안 관련 실무경력
- 다. 정보보안 관련 직무교육 이수 등

3. 정보보안실무책임자는 정보보안 조직 구성원의 역할과 책임에 대한 명확성을 위하여 직무기술서를 작성, 유지한다.

제10조(정보보안 교육) ①정보보안담당관은 본교 전체 직원을 대상으로 연 1회 이상 정보보안 교육을 실시한다.

②정보보안담당관은 제1항에 의한 교육을 실시할 때에는 외부의 정보보안 관련 전문기관에 이를 위탁하여 실시할 수 있다.

③정보보안실무책임자는 다음 각 호의 내용을 포함한 연간 정보보호교육계획을 수립하여 연 1회 이상 교육을 시행하고 그 결과를 정보보안담당관에게 보고한다.

1. 본교 교직원 및 관련 외부자에 대한 정보보호 및 개인정보보호 인식 제고를 위한 교육
2. 정보보호 조직 및 IT 업무담당자의 역량강화를 위한 전문 보안교육
3. 정보보호 교육에 대한 세부사항은 『정보보호교육수행 지침』에서 정한다.

제11조(사이버보안진단의 날) ①정보보안담당관은 매월 세 번째 수요일을 “사이버보안진단의 날”로 지정·운영 하여야 한다.

②각 부서 분임정보보안담당관의 책임하에 본교 구성원들은 사이버보안진단을 수행하여야 하며 안전한 진단 결과 달성을 위하여 노력하여야 한다.

제12조(보안점검) ①정보보안실무책임자는 점검조직 구성, 점검방법, 점검시기 등을 정한 정보보호 점검계획을 수립하여 연 1회 이상 정보보호 점검을 실시하여야 한다.

②정보보안실무책임자는 정보보호 감사 완료 후 보안점검 결과를 작성하여 정보보안담당관에게 보고하여야 한다.

③본교의 정보보안 내규 및 지침을 위반한 교직원에 대해서는 『인사보안 지침』의 징계기준에 의거하여 조치하여야 한다.

④보안점검에 대한 세부적인 사항은 『보안점검 지침』에서 정한다.

제13조(정보자산 분류 및 통제) ①본교의 정보자산의 관리책임은 정보자산의 생성자 및 소유자에게 있으며, 정보보안담당자는 정보자산을 보호하기 위한 대책을 수립한다.

②하드웨어, 소프트웨어 및 기타장비의 자산목록은 관리대장 형태 또는 자산관리 프로그램 형태로 유지 관리한다.

③문서자산의 경우 기밀성을 고려하여 각각 기밀, 대외비, 일반 문서로 분류하고 다음 각 호의 기준에 따라 관리한다.

1. 기밀 : 교직원의 적격심사 및 신원조회 결과, 중대한 보안사고 처리결과 등 본교에서 업무관계자 이외에 노출이 극히 제한되어야 하는 정보
2. 대외비 : 정보시스템 관련 정보, 네트워크 구성도 등 외부에 노출 또는 유출이 엄격히 통제되어야 하는 정보

3. 일반 : 기밀 및 대외비에 해당되지 않은 정보

④정보자산을 폐기하는 경우 정보자산의 유형에 따라 폐기한다.

⑤정보자산은 자산등록, 변경, 폐기절차에 따라 관리되어야 한다.

⑥정보자산 분류 및 관리에 대한 세부사항은 『정보자산관리 지침』에서 정한다.

제14조(정보자산의 위험분석) ①정보보안실무책임자는 식별된 정보자산에 대해 중요도를 산정하고 취약성, 위협요소 등을 고려하여 정기적으로 연 1회 이상 위험분석을 실시해야 한다.

②위험분석 결과 도출된 위협에 대해서는 “위험관리계획서”의 작성을 통해 전담인원, 기간, 예산 등 전반적인 위험관리 방안을 정의하여 관리해야 한다.

③위험분석 및 위험관리에 대한 세부사항은 『위험관리 지침』에서 정한다.

제15조(비밀유지의 의무) ①본교 교직원은 입사 시, 재직 시, 퇴사 시 보안관리 규정 및 지침을 준수할 의무가 있으며, 이를 위반 시 징계 및 해고의 사유가 될 수 있다.

②본교 교직원 및 외부자는 업무 중 취득한 비밀을 지정된 업무 이외의 목적에 사용하여서는 아니 된다.

③본교 교직원 및 외부자는 본교와의 계약 종료 시 모든 본교의 자산과 소유물을 반납하여야 한다.

④본교 교직원 및 외부자는 직무상 알게 된 정보자산 관련 비밀을 지킬 의무가 명시된 정보보호 서약서에 서명해야 한다.

⑤비밀유지의 의무에 대한 세부적인 사항은 『인사보안 지침』에서 정한다.

제16조(외부자 보안) ①외부자와 서비스 또는 용역 제공과 관련하여 계약서를 작성할 경우, 본교의 보안관리 규정 및 기준을 반영하고 교육 등을 통해 본교의 정보보호 요구사항을 외부자에게 주지시켜야 한다.

②외부자에게 계약수행을 위해 필요한 논리적, 물리적 접근권한을 부여 할 경우, 이에 대한 적절한 통제대책을 마련해야 한다.

③외부자 보안에 대한 세부사항은 『인사보안 지침』에서 정한다.

제17조(보호구역의 설정) ①중요정보가 보관되거나 처리되는 지역은 사전에 보호구역으로 설정하여 비인가자의 출입으로부터 보호하여야 한다.

②보호구역은 비인가자의 접근이나 손상을 방지하기 위하여 별도의 출입통제 장치 및 감시시설, 채해방지 시설 등을 갖추어야 한다.(예 : 전산센터)

③보호구역의 설정에 대한 세부사항은 『물리보안 지침』에서 정한다.

제18조(보호구역의 출입통제) ①보호구역에 대한 교직원의 접근권한이 적절하게 부여되고 있는지 주기적으로 점검하여야 한다.

②비인가자의 보호구역(통제구역) 출입이 필요한 경우에는 반드시 업무담당자와 동행하여야 하며, 출입목적에 따라 인가하고 그 사실을 기록관리 하여야 한다.

③보호구역 내에서 정보자산 반출·입이 필요한 경우에는 반출·입 절차에 따라 출입기록이 관리되어야 한다.

④보호구역 출입통제에 대한 세부적인 사항은 『물리보안 지침』에서 정한다.

제19조(사무공간 보호) ①퇴근 시나 장기 외출 시, 문서는 책상 위에 방치되어서는 안 되며 잠금장치가 부착된 문서 보관함 등에 보관되어야 한다.

②장시간 이석 할 경우, PC는 화면보호기에 의해 화면이 자동으로 잠기도록 설정하여야 한다.

③사무공간 보호에 대한 세부사항은 『PC 및 사용자보안 지침』에서 정한다.

제20조(PC 등 단말기 보안관리) ①이용자 및 사용자는 PC·노트북 등 단말기 사용과 관련한 일체의 보안관리 책임을 가진다.

②이용자 및 사용자는 비인가자가 PC 등을 무단으로 조작하여 전산자료를 절취, 위·변조 및 훼손시키지 못하도록 다음 각 호의 보안대책을 준수하여야 한다.

1. 장비·자료·사용자별 비밀번호를 주기적으로 변경 사용
2. 10분 이상 PC 작업 중단 시 비밀번호가 적용된 화면보호 조치
3. 운영체제(OS) 및 응용프로그램의 최신 보안패치 유지
4. 최신 바이러스 백신 설치 및 수시 점검
5. 업무상 불필요한 응용프로그램 설치 금지 및 공유 폴더의 삭제

③이용자 및 사용자는 PC 등 단말기를 교체·반납·폐기하거나 고장으로 외부에 수리를 의뢰하고자 할 경우에는 하드디스크에 수록된 자료가 유출·훼손되지 않도록 보안조치 하여야 한다.

④이용자 및 사용자는 업무상 필요한 PC내의 데이터는 별도의 저장장치를 통해서 백업을 하여 만일의 사태에 대비해야 한다.

⑤부서 분임정보보안담당관은 정보보안담당관 총괄 하에 제2항 각 호에 해당하는 보안대책의 준수 여부를 정기적으로 점검하고 개선 조치하여야 한다.

제21조(접근통제) ①정보시스템의 비인가 된 침해를 방지하기 위하여 정보자산 별로 적절한 접근 통제 정책을 수립 및 시행하여야 한다.

②정보시스템은 반드시 사용자 인증과정을 통해 접근이 가능하도록 하여야 한다.

③정보시스템에는 사용자에게 업무 수행에 필요한 최소한의 권한만을 부여하여야 한다.

④접근통제 정책은 주기적으로 점검하여, 접근통제 정책의 적정성을 확인하여야 한다.

⑤프로그램 개발 및 테스트는 운영시스템과 분리되어 이루어져야 하며, 운영 시스템 이관 전 충분한 테스트 및 정보보안실무책임자의 승인을 득하여 적용하여야 한다.

⑥정보시스템 및 정보자산 별 접근통제에 대한 세부사항은 『서버보안 지침』, 『데이터베이스보안 지침』, 『네트워크보안 지침』, 『정보보호시스템보안 지침』, 『응용프로그램보안 지침』에서 정한다.

제22조(정보시스템 보안관리 및 보안점검) ①전산센터에 위치한 정보운영팀 정보시스템의 보안관리 및 보안점검은 정보보안담당부서에서 실시한다.

②전산센터에 위치한 기타 부서 정보시스템은 전산센터 정보보호시스템의 기본적인 보호를 받으나 정보시스템의 보안관리 및 보안점검은 해당 부서에서 실시한다.

③전산센터 밖에 위치한 기타 부서 정보시스템은 해당 부서에서 보안관리 및 보안점검을 실시한다.

④정보시스템, 응용프로그램, 운영프로그램의 변경 통제에 대한 절차가 규정되어 준수되어야 한다.

⑤정보시스템의 오류, 서비스 중단, 서비스 거부, 불완전한 데이터로 야기되는 오류, 기밀성 침해 등이 발생할 경우, 정의된 침해사고 및 정보시스템 장애 보고절차를 준수하여야 한다.

⑥본교 내 주요 정보시스템을 대상으로 취약점 분석을 주기적으로 실시하며, 분석을 담당하는 부서(자)는 조치내역을 정보보안담당자에게 보고해야 한다.

⑦정보시스템 도입 시 보안점검을 수행하고 정보자산 분류 기준에 따라 목록화하여야 한다.

⑧정보시스템 운영 시 반드시 접근통제를 실시하고 보안패치, 최신 버전의 백신을 설치 후 운영하여야 한다.

⑨정보시스템의 성능과 용량에 대하여 주기적으로 모니터링을 실시하여 그 기록을 유지해야 한다.

⑩정보시스템의 철수 및 폐기 시 서버의 구성과 관련된 설정 및 저장정보를 완전히 삭제하고 책임자의 승인을 득한 후 폐기해야 한다.

⑪정보시스템 보안관리 및 보안점검의 세부 운영사항은 『서버보안 지침』, 『데이터베이스보안 지침』, 『네트워크보안 지침』, 『정보보호시스템보안 지침』, 『응용프로그램보안 지침』, 『정보자산관리 지침』에서 정한다.

제23조(서버 백업 및 로그관리) ①서버담당자는 중요한 정보와 소프트웨어에 대한 백업 및 복구 계획을 수립하여 주기적(년 1회 이상)으로 점검하여야 한다.

②서버담당자는 백업 미디어에 대한 소산 계획을 수립하여 안전한 곳에 소산한다.

③서버담당자는 시스템 운영 로그를 보관, 관리해야 하며 이를 감사 물증 또는 침해사고의 증거 자료로 제출 할 수 있도록 관리하여야 한다.

④서버 백업 및 로그관리의 세부 운영사항은 『장애관리 지침』에서 정한다.

제24조(전산자료 및 문서자료 보관) ①개인정보 등 중요정보를 담고 있는 전산(문서)자료는 물리적으로 안전하게 보관되어야 한다.

②전산(문서)자료를 폐기할 경우, 저장 내용을 식별할 수 없도록 소각, 파쇄 등의 방법을 사용하여 폐기하여야 한다.

③전산(문서)자료를 소산 보관하거나 필요에 의하여 타 지역으로 이동시킬 경우, 도난이나 분실을 방지하기 위한 대책이 적용되어야 한다.

제25조(보안시스템 운영 및 보안관리) ①정보시스템의 정보보호를 강화하기 위하여 적절한 보안시스템을 운영하여야 한다.

②보안시스템의 보안정책에 대한 변경 통제가 적절한지 주기적으로 검토하여야 한다.

③보안시스템의 세부 운영사항은 『정보보호시스템보안 지침』에서 정한다.

제26조(보안 요구사항 정의) ①신규 프로그램 개발 또는 변경 시 요구되는 보안 기능이 정의되어야 한다.

②프로그램 개발 또는 변경 시 요구분석 및 설계단계에 정보보호 기능에 대한 요건을 정의하고, 이를 바탕으로 한 검증절차를 수행하여야 한다.

③정보의 손실, 변조, 오용을 방지하기 위하여 입/출력 데이터 유효성 검증 기능 및 감사추적을 위한 로그 저장기능이 제공 되어야 한다.

④응용시스템 개발 및 변경은 공식적인 변경절차를 통해 수행되어야 한다.

⑤정보의 기밀성과 무결성 보호 및 부인방지를 위하여 적절한 수준의 암호화가 이루어져야 한다.

⑥보안 요구사항 정의의 세부 운영사항은 『응용프로그램보안 지침』에서 정한다.

제27조(응용프로그램 파일 보호) ①개발이 완료된 응용프로그램을 실 운영 중 인 시스템에 이관하기 전 충분한 테스트 과정을 거쳐야 하며, 테스트 결과에 대한 관리자의 승인을 얻은 후 운영 시스템에 적용해야 한다.

②개발소스 프로그램 및 데이터 라이브러리의 변조 또는 비인가 된 접근을 방지하기 위하여 엄격한 접근 통제가 이루어져야 한다.

③응용프로그램 파일 보호의 세부 운영사항은 『응용프로그램보안 지침』에서 정한다.

제28조(데이터베이스 보안) ①데이터의 정확도를 신뢰할 수 있도록 데이터베이스의 수정은 적법한 절차에 의해서만 이루어져야 한다.

②데이터베이스의 무결성을 유지하기 위해 주기적인 백업을 실시하여야 한다.

③데이터베이스의 중요 데이터에 대한 접근기록을 유지하여야 하며, 필요한 경우 중요 데이터는 암호화하여 저장하여야 한다.

④데이터베이스 보안의 세부 운영사항은 『데이터베이스보안 지침』에서 정한다.

제29조(침해사고 예방 및 대응) ①정보보안담당관은 침해사고 예방 및 대응 계획을 수립 한다.

②정보보안실무책임자는 침해사고 예방 및 대응 계획에 따라 필요한 업무를 수행한다.

③정보보안담당자는 침해사고 예방을 위하여 주기적으로 정보시스템 취약점을 점검하고 그 결과에 따라 필요한 조치를 수행한다.

④침해사고 발생 시 정보보안담당자는 즉각적인 대응조치를 취하고 적절한 증거자료를 수집·보관하여 침해사고 사실을 정보보안실무책임자 및 정보보안담당관에게 문서로 보고하여야 한다.

⑤정보보안담당관은 긴급한 침해사고가 발생하였을 경우 모든 이용자에게 대응책을 신속하게 알릴 수 있어야 한다.

제30조(IT 재해복구 관리) ①본교는 천재지변, 화재, 폭동, 침해사고, 설비장애 등으로 인해 발생할 수 있는 IT재해에 대비하여 대응절차를 개발하고, 조직 및 관리 절차를 수립하여야 한다.

②비상사태 발생 시 업무의 계획적 운영과 업무 중단 시 최단시간 내에 업무를 재개할 수 있도록 업무 우선순위에 따라 비상계획이 수립되고 운용되어야 한다.

③IT재해 대응절차의 변경 절차가 수립되어야 하며, 변경된 IT재해 대응절차를 교직원에게 교육하고 공지하여야 한다.

④IT 재해복구에 대한 세부사항은 『IT 재해복구 지침』에서 정한다.

제31조(개인정보 보호) ①본교에서 이용자(학생 등) 및 교직원의 개인정보 보호를 위한 보호계획을 수립하여 운영하도록 한다.

②개인정보 보호를 위해 개인정보 보호책임자(CPO), 개인정보 보호담당관을 지정하여 운영하고, 업무상 개인정보를 처리하는 교직원(예 : 개인정보 취급자)에 대해서는 목록으로 관리하여야 한다.

③본교에서 처리하는 개인정보가 외부에 노출되지 않도록 기술적/관리적 조치를 통하여 보호하여야 한다.

④개인정보 보호에 대한 세부사항은 『개인정보보호 규정』에서 정한다.

제32조(법적 요구사항에 대한 부합성) ①본교에서 정보보안 업무활동은 유관기관의 관계법령을 준수하여 이루어져야 하며, 관련 법률의 개정 및 제도의 변경 등이 발생한 경우 이를 반영하여야 한다.

②본교의 업무담당자는 저작권, 라이선스, 지적재산권 보안규정을 준수하여 정품 출판물 및 소프트웨어 제품을 사용한다.

③본교의 기밀자료는 손실, 파괴, 변조로부터 안전하게 보호되도록 조치하며, 관련 법규가 정하는 바에 의하여 보관한다.

④본교 정보시스템에 암호화를 적용할 경우 암호화는 관련 법규가 정하는 바에 의하여 사용되어야 한다.

⑤보안사고 발생 시 법적 대응을 위하여 침해를 증명할 수 있는 자료에 대한 수집은 관련 법규가 정하는 바에 의하여 이루어져야 한다.

제 4 장 기 타

제33조(내부지침) 이 내규의 운용에 필요한 세부사항은 내부지침으로 따로 정할 수 있다.

제34조(준용) 이 내규에 명시되지 않은 사항은 교육부 「정보보안 기본지침」 및 관련 법률에 따른다.

3-1-75~8 일반행정

부 칙(2019. 12. 4.)

이 내규는 2019년 12월 4일부터 시행한다.